



Raport Bezpieczeństwa - Juice Shop

Site: <http://localhost:3000>

Generated on czw., 7 maj 2026 18:25:12

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Poziom ryzyka	Number of Alerts
Wysoki	0
redni	4
Niski	3
Informacyjny	2
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	4
Low	Warning		ZAP warnings logged - see the zap. log file for details	7
Low	Exceeded High	http://localhost:3000	Percentage of responses with status code 4xx	65 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	3 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	20 %
Info	Informational		Percentage of responses	7 %

		http://localhost:3000	with status code 3xx	
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 5xx	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	18 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	16 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/octet-stream	10 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type font/woff2	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/png	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	2 %
			Percentage of endpoints	

Info	Informational	http://localhost:3000	with content type text/css	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	28 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/markdown	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	95 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	4 %
Info	Informational	http://localhost:3000	Count of total endpoints	49
Info	Informational	http://localhost:3000	Percentage of slow responses	2 %

Zagrozenia

Nazwa	Poziom ryzyka	Number of Instances
Content Security Policy (CSP) Header Not Set	redni	Systemic
Cross-Domain Misconfiguration	redni	Systemic
Missing Anti-clickjacking Header	redni	2
Session ID in URL Rewrite	redni	Systemic
Private IP Disclosure	Niski	1
Timestamp Disclosure - Unix	Niski	Systemic
X-Content-Type-Options Header Missing	Niski	4
Information Disclosure - Suspicious Comments	Informacyjny	4
Modern Web Application	Informacyjny	4

Alert Detail

redni	Content Security Policy (CSP) Header Not Set
Opis	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	
Other Info	
URL	http://localhost:3000/ftp
Node Name	http://localhost:3000/ftp
Metody	GET
Atak	
Evidence	
Other Info	
URL	http://localhost:3000/ftp/coupons_2013.md.bak
Node Name	http://localhost:3000/ftp/coupons_2013.md.bak
Metody	GET
Atak	
Evidence	
Other Info	
URL	http://localhost:3000/ftp/eastere.gg
Node Name	http://localhost:3000/ftp/eastere.gg
Metody	GET
Atak	
Evidence	
Other Info	
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Metody	GET

Atak	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

redni	Cross-Domain Misconfiguration
Opis	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/chunk-24EZLZ4I.js
Node Name	http://localhost:3000/chunk-24EZLZ4I.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

redni	Missing Anti-clickjacking Header
--------------	---

Opis	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GOP_0&sid=uDBufq1erHGzxUZiAAFK
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(1)
Metody	POST
Atak	
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKSe&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	
Other Info	
Instances	2
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

redni	Session ID in URL Rewrite
--------------	----------------------------------

Opis	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKSf&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Metody	GET
Atak	

Evidence	Yi8GUjbfXE7hmt66AAE6
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GK_Z&sid=az8ZaOLXKB9HpgMSAAE8
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Metody	GET
Atak	
Evidence	az8ZaOLXKB9HpgMSAAE8
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,transport)
Metody	GET
Atak	
Evidence	Yi8GUjbfXE7hmt66AAE6
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKSe&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	Yi8GUjbfXE7hmt66AAE6
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GK_T&sid=az8ZaOLXKB9HpgMSAAE8
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	az8ZaOLXKB9HpgMSAAE8
Other Info	
Instances	Systemic
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.
Reference	https://seclists.org/webappsec/2002/q4/111
CWE Id	598
WASC Id	13
Plugin Id	3

Niski

Private IP Disclosure

Opis	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://localhost:3000/rest/admin/application-configuration
Node Name	http://localhost:3000/rest/admin/application-configuration
Metody	GET
Atak	
Evidence	192.168.99.100:3000
Other Info	192.168.99.100:3000 192.168.99.100:4200
Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP /PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
CWE Id	497
WASC Id	13
Plugin Id	2

Niski	Timestamp Disclosure - Unix
Opis	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	1650485437
Other Info	1650485437, which evaluates to: 2022-04-20 22:10:37.
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	1981395349
Other Info	1981395349, which evaluates to: 2032-10-14 21:35:49.
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	2038834951
Other Info	2038834951, which evaluates to: 2034-08-10 17:02:31.
URL	http://localhost:3000/sitemap.xml

Node Name	http://localhost:3000/sitemap.xml
Metody	GET
Atak	
Evidence	1650485437
Other Info	1650485437, which evaluates to: 2022-04-20 22:10:37.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Metody	GET
Atak	
Evidence	2038834951
Other Info	2038834951, which evaluates to: 2034-08-10 17:02:31.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Niski	X-Content-Type-Options Header Missing
Opis	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKSf&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Metody	GET
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKLN
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Metody	GET
Atak	
Evidence	
Other	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages

Info	away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GOP__0&sid=uDBufq1erHGzxUZiAAFK
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(1)
Metody	POST
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pu3GKSe&sid=Yi8GUjbfXE7hmt66AAE6
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informacyjny	Information Disclosure - Suspicious Comments
Opis	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:3000/chunk-BYFFE6ZA.js
Node Name	http://localhost:3000/chunk-BYFFE6ZA.js
Metody	GET
Atak	
Evidence	db
Other Info	The following pattern was used: \bDB\b and was detected in likely comment: "//angular.dev/best-practices/security#preventing-cross-site-scripting-xss",v=class extends Error{code; constructor(t,n){super(Ye(" see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/chunk-MDFPGS4J.js
Node	

Name	http://localhost:3000/chunk-MDFPGS4J.js
Metody	GET
Atak	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "///"))`:t} else{let t=dh(i,(e,r)=>r===w?[Zi(i.children[w],!1)]:[`\${r}:\${Zi(e,!1)}`]);return Object.keys(i.children).length===1&&i", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/hacking-instructor-OYUKCDGG.js
Node Name	http://localhost:3000/hacking-instructor-OYUKCDGG.js
Metody	GET
Atak	
Evidence	query
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "///w.soundcloud.com/player/?url=https%3A//api.soundcloud.com/tracks/771984076& color=%23ff5500&auto_play=true&h", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/main.js
Node Name	http://localhost:3000/main.js
Metody	GET
Atak	
Evidence	query
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "///+e.host),typeof t=="string"&&(t.charAt(0)==="/"&&(t.charAt(1)==="/"?t=e.protocol+t:e.host+t),/^((https? wss?):\\/.test(t))", see evidence field for the suspicious comment/snippet.
Instances	4
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informacyjny	Modern Web Application
Opis	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:3000
Node Name	http://localhost:3000
Metody	GET
Atak	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })); </script>
Other	No links have been found while there are scripts, which is an indication that this is a modern

Info	web application.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Metody	GET
Atak	
Evidence	<pre><script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })); </script></pre>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/ftp/
Node Name	http://localhost:3000/ftp/
Metody	GET
Atak	
Evidence	<pre>ftp</pre>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Metody	GET
Atak	
Evidence	<pre><script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })); </script></pre>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	4
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109